FINDSERVICES THREAT MODELING INTELLIGENCE | Praktikum Keamanan Sistem Informasi

`Metodologi: STRIDE + DREAD` `Target: Laravel 12.x`

Laporan Analisis Ancaman & Pemetaan Keamanan Sistem

INFOGRAFIK THREAT MODELING

Pemetaan komprehensif profil sistem, DFD 5–Trust Boundaries, simulasi alur kerja pengguna, metrik risiko STRIDE-DREAD, serta katalog mitigasi teknis untuk repositori **FindServices**.

CRITICAL	HIGH RISK	MITIGATED	AVG DREAD
2 Ancaman	7 Ancaman	1 Low	33.8 / 50

01

Karakteristik target aplikasi, profil aktor, tumpukan teknologi, dan ruang lingkup audit

Identitas & Tujuan Platform

FindServices adalah platform marketplace berbasis web yang memfasilitasi pencarian dan pemesanan penyedia jasa lokal (tukang/teknisi) terdekat.

Fitur Utama:	Haversine GPS, Chat Socket, Midtrans
Basis Jarak:	Radius Koordinat Latitude / Longitude
Tipe Transaksi:	Escrow Digital (Snap) & Tunai (COD)

Stack Teknologi Terverifikasi

Backend Framework	Frontend Stack
Laravel 12 (PHP 8.3)	Vue 3 + Inertia.js

Database Utama MySQL 8.0 Engine	Real-time Engine Laravel Reverb :8080
Payment Gateway Midtrans Snap API	Ingress / Tunnel Cloudflare Tunnel

Aktor Pengguna & Batasan Ruang Lingkup

CUSTOMER	Pencari jasa, membuat booking, bayar, rating review.
PROVIDER	Penyedia jasa, verifikasi order, negosiasi harga, eksekusi.
ADMIN	Pengelola master data kategori, resolusi dispute & audit.

Ruang Lingkup: Static code review, audit konfigurasi environment (.env), dan threat modeling non-destruktif.

Inventarisasi 10 Komponen Sistem Kunci (K-01 s/d K-10)

Modul Autentikasi & Akun (Auth & ProfileController) — KREDENSIAL A
Registrasi, login sesi, update pr…
Atribut 'role' sempat terbuka di mass assignment model User;…

Modul Pemesanan & Alur Status (BookingController) — INTEGRITAS T
Membuat booking, validasi kuo…
Pengecekan hak akses auth()->id() di updateStatus sempat…

Modul Gateway Pembayaran (PaymentCallbackController) — INTEGRITAS
Request token Snap Midtrans d…
Route webhook CSRF-exempt; verifikasi SHA512 rentan bypass bil…

Modul Marketplace & Geolokasi (MarketplaceController) — KETERSE
Katalog jasa dengan filter kateg…
Kalkulasi rumus Haversine intensif CPU tanpa caching database…

Modul Manajemen Jasa & Galeri (ServiceController) — INTEGRITAS D
Publikasi jasa, deskripsi layana…
Batas upload 10MB hanya validasi tipe MIME dasar tanpa inspeksi…

Modul Percakapan Realtime (ChatController & Reverb) — KERAHASIAAN
Pengiriman pesan teks instan, p…
Endpoint /api/test-latency tanpa autentikasi berpotensi membanjiri…

Modul Ulasan & Rating (Review & BookingController) — REPUTASI PRO
Menyimpan penilaian rating bin…
Input teks review rentan Stored XSS jika direnderr mentah (v-html) tanpa…

Modul Administrasi & Pengaduan (Admin Controllers) — HAK AKSES AD
Manajemen kategori jasa, pena…
AdminMiddleware mengandalkan field role pada model User; route…

Modul Notifikasi Pengguna (NotificationController) — KERAHASIAAN
Mengirim notifikasi pesanan, p…
Kredensial SMTP Gmail di .env harus dilindungi dari pembacaan pihak…

Penyimpanan Database & Sesi (MySQL Database Engine) — INTEGRITAS D
Menyimpan tabel users, service…

Perlu prepared statement konsisten dan enkripsi sesi agar terhindar dari...

02 User journey dari pencarian hingga penyelesaian layanan dengan penanda potensi ancaman (Touchpoints)

1 DISCOVERY

Pencarian & Otentikasi

Customer login, mencari jasa terdekat berbasis koordinat geolokasi (Haversine formula).

TITIK RAWAN (THREAT):

T-04 (DoS) T-08 (Session)

2 BOOKING

Pemesanan & Penawaran

Customer membuat order pesanan. Provider mereview, menyepakati harga final, dan konfirmasi.

TITIK RAWAN (THREAT):

T-01 (IDOR) T-06 (Privilege)

3 PAYMENT

Pembayaran & Escrow

Customer membayar via Midtrans Snap. Sistem menunggu callback webhook untuk validasi lunas.

TITIK RAWAN (THREAT):

T-03 (Webhook)

4 REALTIME

Komunikasi & Pengerjaan

Provider & Customer berinteraksi via chat WebSocket Laravel Reverb hingga pekerjaan selesai.

TITIK RAWAN (THREAT):

T-02 (DoS) T-09 (Hashids)

5

COMPLETION

Review, Rating & Selesai

Customer mengonfirmasi selesai, memberikan ulasan review, rating, dan foto bukti pengerjaan.

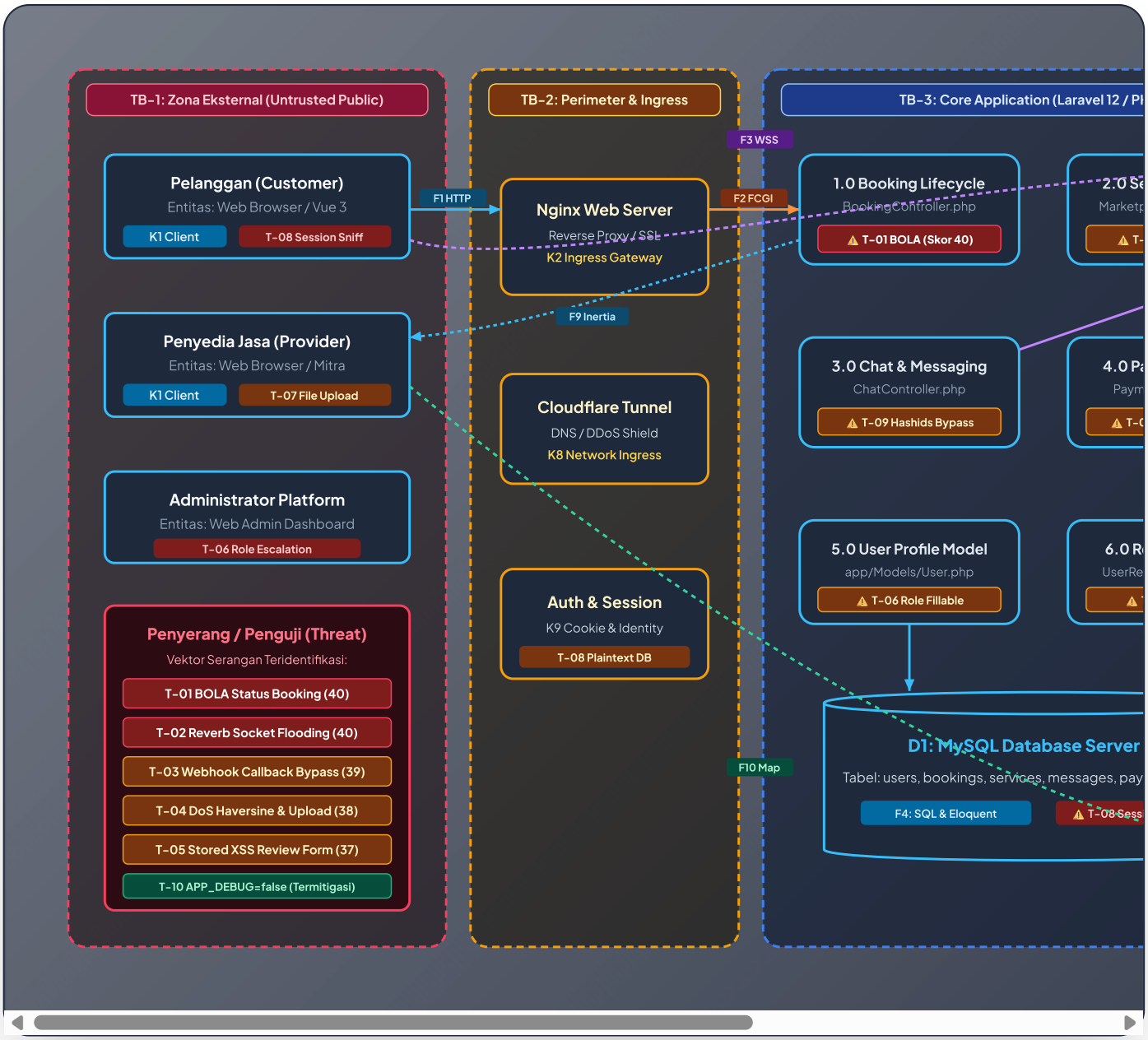
TITIK RAWAN (THREAT):

T-05 (XSS) T-07 (Upload)

03

Pemetaan relasional entitas, proses inti, data store, dan 5 batas kepercayaan (TB-1 s/d TB-5)

TB-1 TB-2 TB-3 TB-4 TB-5



LEGENDA NOTASI:

Entitas Eksternal (Kotak) · Proses Aplikasi (Rounded) · Data Store / DB (Silinder)

Trust Boundary (Dashed Border) · T# Penanda Titik Ancaman

04

Distribusi tingkat keparahan risiko, klasifikasi STRIDE, profil skor DREAD, dan status mitigasi

DISTRIBUSI LEVEL RISIKO

CRITICAL (Skor 40–50) 2 (20%)

HIGH (Skor 25–39) 7 (70%)

MEDIUM (Skor 15–24) 0 (0%)

LOW / MITIGATED (≤14) 1 (10%)

Sebanyak **90%** ancaman berada pada spektrum kritis & tinggi yang memerlukan penanganan langsung.

DISTRIBUSI KATEGORI STRIDE

Spoofing: 2 ancaman	Tampering: 6 ancaman
Repudiation: 0 ancaman	Information Disclosure: 5 ancaman
Denial of Service: 2 ancaman	Elevation of Privilege: 2 ancaman

Kategori dominan adalah **Tampering (6)** dan **Information Disclosure (5)**.

TEMUAN KRITIS UTAMA & BUKTI KODE SUMBER

T-01: BOLA / IDOR Status Booking (Skor 40 – CRITICAL) CVE-2023-28438

Pengecekan hak akses `auth()→id()` dikomentari pada BookingController.php:230. Siapa saja dapat mengubah status pesanan milik pengguna lain!

T-02: Unauthenticated Socket Flooding DoS (Skor 40 – CRITICAL) CVE-2023-34449

Endpoint `POST /api/test-latency` di routes/api.php:15 bebas diakses publik tanpa middleware auth/rate limiter, memicu event broadcast tak terbatas.

Mitigasi Berhasil: APP_DEBUG=false TERVERIFIKASI

T-10 dinonaktifkan di .env baris 4. Skor DREAD turun dari 43 (Critical) menjadi 6 (Low).

05

Rincian parameter STRIDE, skor DREAD, bukti kode, dan solusi teknis terstruktur

T-01 (CVE-2023-28438) T E

CRITICAL

Skor: 40/50

Penyerang yang terautentikasi memanipulasi parameter order_id pada endpoint status booking di BookingController tanpa verifikasi kepemilikan akun, sehingga dapat mengubah status pesanan milik pengguna lain secara sepihak.

Damage	Reprod	Exploit	Affected	Discov
8	9	8	8	7

Bukti Kode Sumber:

```
BookingController.php baris 228-232: pengecekan hak akses kepemilikan auth()→id() dikomentari s
ehingga siapa pun dapat mengubah status booking.
```

Alasan Skoring: Damage 8: penyerang dapat membatalkan atau mengubah sepihak status transaksi pengguna lain; Reproducibility 9: serangan sangat mudah diulang dengan mengganti parameter booking ID; Exploitability 8: dapat dieksekusi dengan request HTTP PATCH sederhana; Affected Users 8: berdampak pada seluruh pengguna aktif sistem; Discoverability 7: celah otorisasi mudah ditemukan melalui inspeksi endpoint API.

Rekomendasi Tindakan Mitigasi:

Aktifkan kembali validasi hak akses kepemilikan if (auth()->id() !== $booking->provider_id && auth()->id() !== $booking->customer_id) abort(403); dan gunakan Laravel Authorization Policy.

T-02 (CVE-2023-34449) D

CRITICAL

Skor: 40/50

Penyerang tanpa autentikasi mengirimkan ribuan request ke endpoint uji latensi WebSocket Reverb secara masif, sehingga membanjiri channel Reverb dan mengakibatkan server socket mengalami kehabisan memori serta lumpuh.

Damage	Reprod	Exploit	Affected	Discov
7	9	9	8	7

Bukti Kode Sumber:

```
routes/api.php baris 15-52: route POST /test-latency memicu TestLatency::dispatch tanpa middlewa
re auth maupun rate limiting.
```

Alasan Skoring: Damage 7: melumpuhkan fitur chat dan notifikasi real-time bagi seluruh pengguna; Reproducibility 9: sangat mudah diulang menggunakan script load testing; Exploitability 9: endpoint terbuka untuk publik tanpa autentikasi; Affected Users 8: memengaruhi seluruh pengguna yang mengandalkan real-time event; Discoverability 7: endpoint /api/test-latency tercantum jelas pada routes/api.php.

Rekomendasi Tindakan Mitigasi:

Hapus route /test-latency pada lingkungan production atau lindungi dengan middleware auth:sanctum dan throttle rate limit 5 request per menit.

T-03 (CVE-2023-45133) S T

HIGH

Skor: 39/50

Penyerang memalsukan notifikasi callback webhook Midtrans dengan mengeksploitasi kemungkinan kunci rahasia kosong pada berkas konfigurasi, sehingga status pembayaran booking berubah menjadi lunas tanpa transfer uang sesungguhnya.

Damage	Reprod	Exploit	Affected	Discov
9	8	7	8	7

Bukti Kode Sumber:

```
PaymentCallbackController.php baris 14-38 dan bootstrap/app.php baris 21-23: route api/midtrans/callback dikecualikan dari CSRF dan .env membiarkan MIDTRANS_SERVER_KEY kosong secara default.
```

Alasan Skoring: Damage 9: menimbulkan kerugian finansial langsung karena pesanan dianggap lunas tanpa pembayaran riil; Reproducibility 8: mudah diulang dengan replay packet HTTP POST; Exploitability 7: membutuhkan pengetahuan format payload Midtrans; Affected Users 8: berdampak pada penyedia jasa dan platform; Discoverability 7: route webhook dikecualikan dari proteksi CSRF di bootstrap/app.php.

Rekomendasi Tindakan Mitigasi:

Validasi ketat konfigurasi MIDTRANS_SERVER_KEY tidak boleh kosong, verifikasi ulang status transaksi langsung ke API Get Status Midtrans, dan catat log audit transaksi.

T-04 (CVE-2023-38035) D

HIGH

Skor: 38/50

Pengguna jahat memicu pencarian katalog dengan koordinat radius geolokasi secara berulang dan mengunggah banyak berkas berukuran 10MB, sehingga membebani CPU database dan menghabiskan ruang penyimpanan server.

Damage	Reprod	Exploit	Affected	Discov
7	8	8	8	7

Bukti Kode Sumber:

```
MarketplaceController.php baris 57-68: query rumus Haversine tanpa indexing spasial dan ProfileUpdateRequest.php / ServiceController.php: batas upload mencapai 10240 KB (10MB) per file.
```

Alasan Skoring: Damage 7: menurunkan responsivitas server dan berisiko server crash karena kehabisan ruang disk; Reproducibility 8: dapat diulang otomatis dengan skrip bot HTTP; Exploitability 8: dapat dilakukan oleh siapa saja yang memiliki akun; Affected Users 8: seluruh pengguna mengalami kelambatan akses; Discoverability 7: batas upload 10MB dan endpoint pencarian publik terlihat langsung di UI.

Rekomendasi Tindakan Mitigasi:

Terapkan caching hasil pencarian geolokasi (Redis/Database), turunkan batas maksimal upload menjadi 2MB, dan pasang rate limiting pada endpoint marketplace.

T-05 (CVE-2024-21501) T I

HIGH

Skor: 37/50

Pengguna menyisipkan skrip berbahaya berupa payload JavaScript pada kolom ulasan review atau catatan pemesanan jasa, sehingga skrip dieksekusi di browser penyedia jasa atau administrator saat membuka halaman.

Damage	Reprod	Exploit	Affected	Discov
7	8	7	8	7

Bukti Kode Sumber:

```
BookingController.php baris 470–502: kolom comment review hanya divalidasi string|max:500 tanpa pembersihan tag HTML (strip_tags atau htmlspecialchars).
```

Alasan Skoring: Damage 7: pencurian sesi token admin/provider atau pengalihan halaman; Reproducibility 8: tersimpan permanen di database dan dieksekusi setiap halaman dibuka; Exploitability 7: membutuhkan keahlian injeksi script dasar; Affected Users 8: berdampak pada semua user yang melihat ulasan/booking tersebut; Discoverability 7: kolom input teks review terbuka luas.

Rekomendasi Tindakan Mitigasi:

Terapkan sanitasi input menggunakan strip_tags() pada backend dan pastikan komponen Vue tidak menggunakan direktif v-html pada rendering konten ulasan.

T-06 (CVE-2023-22809) T E

HIGH

Skor: 37/50

Pengguna mendaftar atau memperbarui profil lalu menambahkan parameter role=admin melalui manipulasi HTTP request payload, sehingga hak akses akun meningkat menjadi administrator karena atribut role masuk ke fillable model.

Damage	Reprod	Exploit	Affected	Discov
9	8	7	7	6

Bukti Kode Sumber:

```
app/Models/User.php baris 26: kolom 'role' terdaftar di properti protected $fillable User model.
```

Alasan Skoring: Damage 9: penyerang memperoleh hak akses penuh mengelola kategori, laporan, dan data seluruh sistem; Reproducibility 8: dapat diulang pada endpoint modifikasi profil; Exploitability 7: membutuhkan pengiriman raw JSON request; Affected Users 7: integritas seluruh sistem terdampak; Discoverability 6: celah mass assignment dapat diprediksi dari struktur Eloquent standar.

Rekomendasi Tindakan Mitigasi:

Keluarkan atribut 'role' dari array $fillable pada model User, dan atur penetapan role hanya melalui seeder atau controller admin khusus.

T-07 (CVE-2024-21516) T I

HIGH

Pengguna mengunggah berkas gambar manipulasi (seperti polyglot file atau SVG berbisa) pada fitur foto jasa dan avatar profil, sehingga berkas berbahaya tersimpan di direktori publik server dan dapat memicu SSRF atau XSS.

Skor: 34/50

Damage	Reprod	Exploit	Affected	Discov
8	7	6	7	6

Bukti Kode Sumber:

```
ServiceController.php baris 63-64 dan UserReportController.php baris 36: validasi hanya memeriks
a ekstensi mimes tanpa verifikasi magic bytes konten gambar.
```

Alasan Skoring: Damage 8: potensi eksekusi script atau pembacaan file internal server; Reproducibility 7: berhasil selama berkas lolos filter ekstensi mime; Exploitability 6: membutuhkan crafting payload file khusus; Affected Users 7: pengunjung dan server berisiko terdampak; Discoverability 6: fitur upload media tersedia di berbagai modul.

Rekomendasi Tindakan Mitigasi:

Gunakan pustaka image processing (seperti Intervention Image) untuk merender ulang dan mengonversi semua gambar ke WebP/JPEG murni, serta nonaktifkan eksekusi skrip di folder storage.

T-08 (CVE-2022-31129) S I

HIGH

Pihak ketiga pada jaringan lokal atau perantara sniffing mencuri session ID pengguna karena konfigurasi sesi di database tidak dienkripsi, sehingga penyerang dapat membajak sesi login pengguna tanpa memerlukan password.

Skor: 34/50

Damage	Reprod	Exploit	Affected	Discov
8	7	6	7	6

Bukti Kode Sumber:

```
.env baris 34-36: SESSION_DRIVER=database dan SESSION_ENCRYPT=false menyimpan payload sesi secar
a plaintext di tabel sessions.
```

Alasan Skoring: Damage 8: akun korban diambil alih sepenuhnya selama sesi masih valid; Reproducibility 7: dapat diulang jika penyerang memperoleh token sesi; Exploitability 6: membutuhkan akses sniffing atau kebocoran database; Affected Users 7: memengaruhi pengguna yang sedang login aktif; Discoverability 6: konfigurasi .env SESSION_ENCRYPT=false dapat diketahui dari audit sistem.

Rekomendasi Tindakan Mitigasi:

Ubah konfigurasi .env menjadi SESSION_ENCRYPT=true dan pastikan flag cookie HttpOnly serta Secure aktif di config/session.php.

T-09 (CVE-2022-31279) T I

HIGH

Skor: 33/50

Pengguna yang terautentikasi memanipulasi parameter hash_id pada URL percakapan atau request penghapusan pesan, sehingga dapat membaca pesan rahasia atau menghapus riwayat chat milik pihak lain tanpa izin.

Damage	Reprod	Exploit	Affected	Discov
6	8	7	6	6

Bukti Kode Sumber:

```
ChatController.php baris 59-97 dan baris 240-253: pemuatan pesan konteks dan validasi kepemilikan mengandalkan decode hash tanpa policy terpusat.
```

Alasan Skoring: Damage 6: kerahasiaan negosiasi dan privasi chat bocor atau hilang; Reproducibility 8: mudah diulang dengan men-decode pola Hashids; Exploitability 7: membutuhkan tebakan atau manipulasi hash parameter; Affected Users 6: terbatas pada pasangan chat yang disasar; Discoverability 6: parameter hash_id tampak jelas pada URL query string.

Rekomendasi Tindakan Mitigasi:

Gunakan Laravel Policy untuk memeriksa relasi pesan sebelum memuat atau menghapus chat, dan jangan jadikan Hashids sebagai satu-satunya lapisan keamanan otorisasi.

T-10 (CVE-2023-40028) I

LOW

Skor: 6/50

[TERMITIGASI] Pengunjung website memicu error sistem untuk melihat tampilan stack trace lengkap dan kredensial sensitif, namun saat ini risiko telah diminimalisasi karena parameter APP_DEBUG telah dinonaktifkan di berkas .env.

Damage	Reprod	Exploit	Affected	Discov
2	1	1	1	1

Bukti Kode Sumber:

```
.env baris 4: parameter APP_DEBUG telah diatur bernilai false (APP_DEBUG=false) sehingga stack trace dan environment variables terlindungi.
```

Alasan Skoring: Damage 2: sistem hanya menampilkan halaman error 500 generik tanpa membocorkan data; Reproducibility 1: tidak lagi dapat direproduksi di lingkungan publik; Exploitability 1: tidak ada data sensitif yang diekspos di browser; Affected Users 1: tidak ada pengguna yang terdampak; Discoverability 1: pemindaian otomatis tidak lagi menemukan celah debug.

Rekomendasi Tindakan Mitigasi:

Pertahankan APP_DEBUG=false pada lingkungan production, aktifkan log rotasi, dan gunakan sentry atau monitoring tertutup untuk pelacakan exception.

06

Saran & Pendapat Ahli Keamanan (Action Roadmap)

Rencana mitigasi bertahap untuk tim pengembang dan pengambil keputusan

FASE 1: SEGERA (0 - 48 JAM) — Hotfix Kritis

Penutupan Celah BOLA & DoS Socket

- **Aktifkan auth check di T-01:** Un-comment pengecekan kepemilikan di `BookingController.php:230`.
- **Proteksi Endpoint T-02:** Hapus atau bungkus route `/api/test-latency` dengan `auth:sanctum` & throttle rate limiter.
- **Validasi MIDTRANS_SERVER_KEY (T-03):** Wajibkan kunci server Midtrans tidak boleh null atau kosong di production.

FASE 2: JANGKA MENENGAH (1-2 MINGGU) — Hardening Kode

Pengerasan Konfigurasi & Input Sanitization

- **Enkripsi Sesi (T-08):** Ubah `SESSION_ENCRYPT=true` di .env dan pasang flag `HttpOnly`, `Secure`.
- **Mass Assignment Fix (T-06):** Keluarkan properti `'role'` dari array `$fillable` model User.
- **Sanitasi XSS & Upload (T-05 & T-07):** Terapkan strip_tags pada komentar review dan validasi magic-bytes untuk upload gambar.

FASE 3: STRATEGIS (1 BULAN) — Arsitektur Tangguh

Infrastruktur & Otomasi DevSecOps

- **Spatial Caching (T-04):** Tambahkan Redis caching untuk query rumus Haversine geolokasi katalog.
- **WAF & Rate Limiting:** Konfigurasikan Cloudflare WAF rule untuk inspeksi webhook payload dan mitigasi DDoS.
- **Automated Security Scanning:** Integrasikan SAST (SonarQube / PHPStan Security) pada CI/CD pipeline GitHub Actions.

Infografik Threat Modeling Sistem Informasi © 2026 FindServices Project. Seluruh data diekstraksi dari lembar kerja `1. template_baru_Praktikum_STRIDE-DREAD.xlsx`.

Dibuat untuk keperluan evaluasi keamanan perangkat lunak, pelaporan audit, dan pembelajaran praktikum keamanan sistem informasi.